

MÁSTER EN *ANÁLISIS DE MALWARE Y REVERSING*



Campus Internacional
CIBERSEGURIDAD

ENIIT
INNOVA IT BUSINESS SCHOOL



UCAM
UNIVERSIDAD
CATÓLICA DE MURCIA

ÍNDICE DE CONTENIDOS

1. ACTIVIDADES INDIVIDUALES	3
1.1. Detección de malware mediante WinDbg y scripts de automatización	4
1.1.1. Enunciado	4
1.1.1.1. Reversing del Kernel en sistemas operativos Windows	4
1.1.1.2. Scripts orientados a capturar código malicioso ejecutado en Ring 0	4
1.1.2. Actividad	5
1.1.2.1. WinDbg	5
1.1.3. Entregables	6
1.1.4. Recursos	7
1.1.5. Consideraciones	7
2. NOTAS	8

1. ACTIVIDADES INDIVIDUALES

Antes de llevar a cabo la actividad individual que aquí se plantea, es recomendable haber indagado en los cinco primeros temas, y a mayores como ejercicio auxiliar, que cada alumno según su interés y conocimiento en la materia, profundice en las operaciones y funcionamiento interno de algún driver que sea extensamente conocido, ya que esto ayudará a comprender mejor las estructuras y llamadas a funciones del kernel, facilitando el adentrarse en el reversing del sistema operativo.

Como ejemplo, y analizando un caso ya comentado durante el módulo, se dejan los siguientes recursos sobre el driver de la herramienta mimikatz (`mimidrv.sys`) a modo de consulta inicial para esta actividad:

- [Github: mimidrv.sys](#)
- [Blog: Mimidrv In Depth](#)
- [Blog: Detecting PPL Manipulation](#)
- [Blog: Disabling LSASS protection with mimidrv.sys](#)
- [Web CodeMachine: Windows kernel data structures](#)

1.1. DETECCIÓN DE MALWARE MEDIANTE WINDBG Y SCRIPTS DE AUTOMATIZACIÓN

1.1.1. ENUNCIADO

1.1.1.1. REVERSING DEL KERNEL EN SISTEMAS OPERATIVOS WINDOWS

Ava, una experta en ciberseguridad y desarrolladora de malware, que actualmente forma parte de un equipo de Red Team, se encuentra indagando en diferentes formas de detección de comportamientos maliciosos.

Como la mayoría de malware, que desarrolla ella, está orientado a sistemas Windows, decide investigar y elaborar un documento guía para explicar al resto de integrantes del equipo, cómo se puede realizar esa detección haciendo ingeniería inversa del kernel de una máquina Windows, utilizando WinDbg.

1.1.1.2. SCRIPTS ORIENTADOS A CAPTURAR CÓDIGO MALICIOSO EJECUTADO EN RING 0

El objetivo es tratar de comprender mejor el uso que se puede hacer de WinDbg para dicha tarea y, ya que se permite, desarrollar un pequeño script para ejecutar a la vez que el malware que programa Sandra, y así conocer si se lanza un comportamiento que se pudiese clasificar como malicioso.

1.1.2. ACTIVIDAD

Este módulo, donde tratamos de explorar de forma completa el concepto de ingeniería inversa en sistemas operativos Windows, se divide en siete áreas que forman parte o están relacionadas con el núcleo de Windows.

En cada uno de los puntos (UEFI, Arranque, Bootkits, Kernel, Protecciones, Debugging y Rootkits), profundizamos de forma técnica, siendo bastante sencillo el ir practicando a la vez que se indaga en el módulo, ya que todos los ejercicios que necesitamos explorar se encuentran en el manual y en los documentos adjuntos.

Esta actividad está pensada para probar el conocimiento adquirido sobre el conjunto de aspectos relacionados con la ejecución de código en ring 0, mediante la explicación del uso de WinDbg para detectar anomalías relacionadas con malware ejecutado a dicho nivel, y el desarrollo de scripts que automaticen esa detección previa.

1.1.2.1. WINDBG

En este punto, ya que previamente para la comprensión de lo expuesto en el tema de debugging habéis realizado de forma manual consultas a estructuras/funciones del kernel, y en definitiva reversing del sistema operativo Windows, como primera actividad, para ahondar aún más en el uso de WinDbg, se propone elaborar un documento resumen en el que se exponga con la teoría aprendida y de forma gráfica (capturas de pantalla, ejecución de comandos, etc), la detección de posibles comportamientos maliciosos, utilizando WinDbg, por ejemplo, monitorización de puertos, conexiones de red, modificación de estructuras, etc.

Además, para automatizar dicha detección, se debe desarrollar un pequeño script utilizando alguna de las tecnologías introducidas en el módulo (scripting de WinDbg, motor JavaScript y librería PyKd), aunque se deja libertad para explorar otras opciones como el desarrollo de una extensión de WinDbg.

1.1.3. ENTREGABLES

En cuanto a la entrega, deberéis crear un proyecto en github, público o privado, cuya url posteriormente indicaréis, y subir a este, al menos, los siguientes ficheros:

- **Readme.md o .pdf:** Documento guía orientado a la explicación, estudio y uso de la herramienta WinDbg para detectar actividades maliciosas en Ring 0.
- **Script.*:** Código fuente, comentado, del script utilizado para automatizar la detección anterior u otra de interés.
- **poc.mp4 (opcional):** Video opcional donde se muestre la ejecución u otros detalles del script o el análisis.

1.1.4. RECURSOS

Para llevar a cabo la actividad, os podéis apoyar, aparte de en los recursos adicionales del módulo, en los siguientes enlaces:

- [Web WinDbg org: WinDbg Quick Links, Extensions, Scripts](#)
- [Github: WinDbg-Samples - Extensions, scripts, and API uses for WinDbg](#)
- [Github: WinDbg_Scripts - Useful scripts for WinDbg](#)
- [Github: Collection of JavaScript debugger extensions for WinDbg](#)
- [GitHub: Awesome WinDbg Extensions](#)
- [Youtube Video: Creating our first WinDbg extension from scratch](#)
- [Python: PyKD](#)
- [Blog: PyKD Tutorial](#)

1.1.5. CONSIDERACIONES

El objetivo último de desarrollar scripts y explicar la detección de forma manual, utilizando WinDbg, de comportamientos maliciosos, es profundizar en el kernel del sistema operativo Windows y realizar ingeniería inversa del mismo. Una vez terminado dicho desarrollo y estudio, para obtener un conocimiento mayor de la materia, se debería indagar, al menos de forma teórica, en estructuras del kernel más complejas.

2. NOTAS

- En relación a la entrega, es importante destacar que cada alumno, según su preferencia, podrá confeccionar los entregables tanto en castellano como en inglés, indistintamente.
- Se sugiere la elección de Markdown o LaTeX para elaborar la documentación que se haga sobre el malware, ya que son lenguajes adecuados cuando se requiere elaborar un documento de manera profesional y estructurada.
- Los alumnos podrán introducir pequeñas variaciones en el enunciado de la actividad para adaptarse al campo de conocimiento que les resulte de mayor interés. Estas modificaciones deberán ser comunicadas para ser validadas previamente a la entrega.
- La suma de las calificaciones de las tareas individuales ponderan un 50% sobre la nota final del módulo.
 - 'Detección de malware mediante WinDbg y scripts de automatización': 25%
- Los alumnos podrán solicitar una o varias sesiones específicas en las que se detalle y resuelva un ejercicio similar, guiando al alumno en la entrega de dicha actividad.